

ERA Security Control “Rosetta Stone” Paper

This is hosted on Google Drive and students should use “File → Make Copy”, not request edit access.

=====

A NOTE ABOUT THIS DOCUMENT.

This document was used by Gerald Auger, PhD to assist in executing an enterprise risk assessment. This is in the language and thought processes of Gerald Auger, PhD. There are no assurances that this document is comprehensive or complete and that executing it alone will provide full coverage over an enterprise and the discovery of cyber risk within it. All organizations are not the same and some controls that are skipped/not developed below do not indicate they are not valid, but they were not for the organization Gerald Auger, PhD was assessing during the creation of this document.

Controls can be audited and assessed multiple ways and the approaches contained herein are not exclusive to identifying if a control is in place or absent.

It is an excellent start to developing a translation document between control language and conversational language.

The course this document is associated with is

<https://academy.simplycyber.io/p/the-definitive-grc-analyst-program>

Thanks

Gerald Auger, PhD

=====

CONTROLS

AC (Target Audience is IT or Identity and Access Management)

AC-1

Is there an access control policy and or procedures?

How do people access them or know they exist?

Review if so for details.

AC-2

What type of user accounts are you using across the organization and applications, and how are you using group/role membership for those user accounts? (Domain admin, Sys admin, app admin, general user, guest accounts, vendor accounts, etc)

Are any types of account strictly prohibited?

How are accounts created and how is it determined what roles and permissions those accounts are given? Are there any approvals required before a user is granted permissions/role/access (new or modified) (network, apps)

What is the process for modifying a users access? (include approvals, documentation, any disabling of prior no longer needed access) (network, apps)

What is the process for disabling a users access? (include timeliness, documentation, validation) (network, apps)

What type of account validation activities occur to ensure that existing accounts with access are appropriate (i.e. to ensure accounts don't slip through the cracks and retain access, especially cloud based apps).

What is the process for changing passwords or authenticators when an individual with access to a shared account no longer needs access (modify, terminated, etc)?

NOTE: For any of these activities if the workflow is mature enough to exist, you can request a list of the last 5 modified and/or disabled users, select 1 randomly and request the artifacts that would support the workflow is being followed correctly.

AC-3

(This should be understood from access management controls to understand if the accounts and permissions being issued are properly allowing access to systems.)

Enforce approved authorizations for logical access to information and system resources in accordance with applicable access control policies.

AC-4

(For any network segmentation, confirm the access is controlled to prevent access to resources that shouldn't be accessed.)

Enforce approved authorizations for controlling the flow of information within the system and between connected systems based on [Assignment: organization-defined information flow control policies].

AC-5

What duties require separation of duties (non-financial)? How are the 2+ roles handled and how do you verify users don't have multiple roles enabling a conflict of duties?

AC-6

How is access given to users to ensure users are not given greater access than what they need to do their job? (i.e. making all of IT domain admins). Any audits of this to ensure compliance with expectations?

AC-10

What restrictions do you have for concurrent sessions by a specific account or account type? How are you limiting it to this number? (Note, for example allowing 1 administrator at a time to login to a server)

Limit the number of concurrent sessions for each [Assignment: organization-defined account and/or account type] to [Assignment: organization-defined number].

AC-12

Do you have any and how is automatically terminating a user sessions configured? (remote access, vpn, citrix, vendor remoting in, RDP, VNC, etc.)

AC-14

What activities or changes to the environment, systems, applications, connections can be done anonymously? i.e. you don't need to login or you could do it from a kiosk.

Is this documented anywhere why its authorized to be done anonymously?

AC-16

(Disregard)

"a. Provide the means to associate [Assignment: organization-defined types of security and privacy attributes] with [Assignment: organization-defined security and privacy attribute values] for information in storage, in process, and/or in transmission;

b. Ensure that the attribute associations are made and retained with the information;

c. Establish the following permitted security and privacy attributes from the attributes defined in AC-16a for [Assignment: organization-defined systems]: [Assignment: organization-defined security and privacy attributes];

d. Determine the following permitted attribute values or ranges for each of the established attributes: [Assignment: organization-defined attribute values or ranges for established attributes];

e. Audit changes to attributes; and

f. Review [Assignment: organization-defined security and privacy attributes] for applicability [Assignment: organization-defined frequency]."

AC-17

What type of remote access is allowed? (employee, IT, vendor, maintenance)

Are there any restrictions? (approved apps, approved protocols, approved windows etc.)

What type of remote access approval/authorization occurs before new remote access is allowed?

AC-18

How is wireless access deployed?

How is it consistently deployed? (any standards)

AC-19

How are mobile devices controlled to access company resources? (MDM, MAM, Forced Pin, Remote wipe)

What is the enrollment process or solution that controls those devices are authorized before getting access to those resources?

AC-20

How are 3rd party systems that store company data engaged to ensure their security level and handling of company data is consistent with company requirements? (could be contractual, could be security review they have to pass).

Are any systems prohibited from use or any conditions that would make a system prohibited from being used?

AC-21

If the company was going to share company data with a 3rd party how is it decided that its appropriate and authorized? (reviews, approvals, legal, procurement may be involved with this)

AC-24

NOT AN INTERVIEW QUESTION

AT (Target Audience is Information Security and/or HR)

AT-1

What is the policy and procedure for security awareness training for staff?

AT-2

How and how often do user receive end user cybersecurity awareness training or education? (include onboarding, a recurring frequency, as needed by role change)

How often and how is the awareness training content updated?

Do the updates include relevant lessons learned from internal incidents or current events?

AT-3

Ask same above questions but qualify it for specific roles (like finance people learn about BEC, or IT learn about not using their Domain Admin account for checking email)

AU (Target Audience IT and Information Security (SecOps))

AU-1

What is the policy and procedure for auditing and audit configuration?

AU-2

What events and settings are logged and with what frequency for endpoints, network devices, servers, etc? How far back do the logs go? (local on endpoint and AD logs, O365 logs for sign-ins and email)

Why were those audit settings selected?

** (Collect Audit Log sample and verify the following audit records contain:

- a. What type of event occurred;
- b. When the event occurred;
- c. Where the event occurred;

- d. Source of the event;
- e. Outcome of the event; and
- f. Identity of any individuals, subjects, or objects/entities associated with the event." **

AU-4

Where do audit logs go and what is the retention capability?

AU-6

AU-7

Is there a SIEM and how/what logs feed into it?

Who has access to SIEM and are logs archived off so there is a preserved record of logs?

AU-12

Are there any logs captured specifically captured for special computers or devices? If yes, what and where? (Confirm they are being captured with a sample)

AU-13

(Ties into Incident Response Plan). How are audit logs monitored for information disclosure (email access, directory access, sensitive computer access).

What type of activities are detected and who is notified if unauthorized information disclosure (or access) is detected?

AU-14

Is there any capability to capture or log a user's session and how is it done, where is it stored, etc. (i.e. Legal suspects a user of stealing information, and you want to monitor, detect, record event)

CA (Target risk, legal, information security)

What policies and procedures are there around assessment, authorization, monitoring of systems?

CA-2

What type of assessments are done

Who is doing assessments (are they qualified),

Is there documentation to support the planning/execution of an assessment?

Is there reporting out on assessments? (where, to whom, and request a sample)

CA-3

When company information is stored in other systems or interconnections are established (and EDI) what terms underpin that connection and business relationship.

What technical, security, privacy aspects of the interconnection are required, documented?

CA-5

How are known weaknesses (specifically captured during an assessment) tracked, monitored, reported, and remediated? (POAM)

How often is the POAM updated?

CA-7

How often are assessments done

What metrics are tracked around assessments and weaknesses?

CA-8

How often are penetration tests done? (internal, external, system specific, etc)

CA-9

What type of configuration or security posture requirements that are enforced for systems (computers, phones, laptops, etc.) connecting to the network?

How is the posture checking made and how are actions taken based on the posture?

"a. Authorize internal connections of [Assignment: organization-defined system components or classes of components] to the system;

b. Document, for each internal connection, the interface characteristics, security and privacy requirements, and the nature of the information communicated;

c. Terminate internal system connections after [Assignment: organization-defined conditions]; and

d. Review [Assignment: organization-defined frequency] the continued need for each internal connection."

CM (Target change management, IT, information security, Applications)

CM-1

What policy and procedures does the company have for configuration management?

CM-2

What current system baselines do you have documented and are in use?

How often is each updated/reviewed?

How are the application of the baseline and the roll out of updates handled?

CM-3

What changes are configuration controlled?

How are changes managed, what's the CCB/CAB workflow and documented (with retention)? (You can request last 5 changes and select 1 and request all pieces of supporting information that validates process is followed.)

Does the config change process have oversight by appropriate stakeholders?

CM-4

Analyze changes to the system to determine potential security and privacy impacts prior to change implementation.

CM-5

What type of physical or logical (technical) restrictions are in place to prevent unauthorized changes? (time locks, authorization, notification alerts configured, etc)

Define, document, approve, and enforce physical and logical access restrictions associated with changes to the system.

CM-6

(Semi covered in CM-2 above, possibly merge this). What security configuration settings are required for systems (documented?).

Are they consistently implemented?

When they are not, is it documented or tracked in any way?

If security settings are changed is there any notification, detection, or awareness?

CM-7

Are systems configured to have services and functions they don't need running disabled? (RDP, IIS, file servers, etc)

CM-8

What system, application inventory do you track and where?

How often is updated or how is it kept current?

What attributes are tracked in this inventory?

CM-9

(DOCUMENT REQUEST) Is there a configuration management plan?

If yes, where is it kept, how is unauthorized modifications to it controlled?

CM-11

What users are authorized to install software on corporate devices? (end users install on own machine?)

How is this controlled and managed? (are there mechanisms for exceptions, etc)

CP (Target IT, Management)

CP-1

What policies and procedures around contingency planning?

CP-2

How is the contingency plan (if exists) socialized, updated, reviewed, approved/supported?

CP-3

How is practicing or executing the contingency plan done?

How are individuals with roles in executing the contingency plan trained in their roles?

CP-4

How is the contingency plan tested? (how, frequency, scope)

Are there lessons learned, after action activities done?

Is the output of these activities used to update systems, processes, documentation?

CP-6

Is there an alternate storage site for backups (data and hardware)?

Data stores replicated

We are at risk of ransomware impact.

Whats the process for retrieving? (time, logistics, access).

How is the data, systems protected at that alt site?

CP-7

Is there an alternate site for resuming business operations (processing) for mission critical business operations?

How is the data, systems protected at that site?

CP-8

Is there alternate telecommunications if primary is not available? (phone/internet) (could be hot, and/or standby)

CP-9

Tell me about backups? (user data, system, documentation)

How often?

How far back is stored?

Is user data backedup? How often, how far back

Are systems backedup? How often, how far back

1. What in your electronic system is not backed up?

Is documentation backed up? How often, how far back

How are all these backups secured? (encrypted, locked room, etc)

CP-10

When you've restored systems, data, how long does it take and was that acceptable to the business? (if RPO/RTO not documented)

CP-11

Whats the process or solution for alternate communications during downtime / executing contingency? (i.e assume work email is down)

CP-12

(skip)

Supplemental Guidance; For systems that support critical mission and business functions—including military operations, civilian space operations, nuclear power plant operations, and air traffic control operations (especially real-time operational environments)—organizations can identify certain conditions under which those systems revert to a predefined safe mode of operation. The safe mode of operation, which can be activated either automatically or manually, restricts the operations that systems can execute when those conditions are encountered. Restriction includes allowing only selected functions to execute that can be carried out under limited power or with reduced communications bandwidth.

When [Assignment: organization-defined conditions] are detected, enter a safe mode of operation with [Assignment: organization-defined restrictions of safe mode of operation].

CP-13

(Need to research more; only thing I can think of is if main authentication method is inaccessible)

We Employ [Assignment: organization-defined alternative or supplemental security mechanisms] for satisfying [Assignment: organization-defined security functions] when the primary means of implementing the security function is unavailable or compromised.

IA (Target IT)

IA-1

What policies and procedures around identity and authentication?

IA-2

How are **users** uniquely identified to systems and the network?

IA-3

How are **devices/systems** uniquely identified to systems and the network?

IA-4

Who and How are usernames/hostnames created and assigned to people/devices?

What is the process (request, approval, creation)?

What is the naming convention?

First.Last@[BusinessUnitEmailDomain]

Are usernames/hostnames/"Identifiers" reused?

Usernames are disabled and not reused in the environment

Hostnames??

IA-5

How are passwords initially communicated users?

How do you verify you are giving the password to the correct person?

Whats the process for lost or compromised authenticators (passwords, hw tokens)?

Whats the process for revoking (passwords, hw tokens)?

Are default credentials changed prior to use? (how do you know; is this communicated?)

Whats the frequency and method for forcing authenticators to change? (password change, hw token OTP rotate)

When people that have access to a shared authenticator (password) no longer need access (modify, terminate) how is that password managed?

IA-7

If PKI is used how do the modules authenticate to the trusted authority?

Implement mechanisms for authentication to a cryptographic module that meet the requirements of applicable laws, executive orders, directives, policies, regulations, standards, and guidelines for such authentication.

IA-8

How are non-org users accounts handled (vendors, contractors, etc)?

IA-9

Are there any (mission-critical (my words)) devices, systems, applications that allow anonymous or shared account access? Why not unique?

IA-10

Do you have any additional authentication or re-authentication mechanisms based on factors (e.g. accessing unusual systems/files, accessing from unusual location, etc)?

Require individuals accessing the system to employ [Assignment: organization-defined supplemental authentication techniques or mechanisms] under specific [Assignment: organization-defined circumstances or situations].

IA-11

When are users required to re-authenticate and how is that technically enforced?

IA-12

How do we verify we are giving credentials to the right person?

IR (Target IT, Information Security, Management)

IR-1

What policies and procedures around Incident Response?

IR-2

What type of IR training do staff receive?

(May ask MDR these IR questions)

IR-3

Is incident response tested?

IR-4

Does IR have a workflow for execution and is it followed?

Lessons learned incorporated?

IR-5

How are incidents tracked and documented.

IR-6

How and when do staff report suspected incidents?

Whats the process for notifying management of incidents?

IR-7

What incident response support resource, integral to the organizational incident response capability, that offers advice and assistance to users of the system for the handling and reporting of incidents is available?

IR-8

Obtain and review the Incident Response Plan for the following:

"a. Develop an incident response plan that:

1. Provides the organization with a roadmap for implementing its incident response capability;
2. Describes the structure and organization of the incident response capability;
3. Provides a high-level approach for how the incident response capability fits into the overall organization;
4. Meets the unique requirements of the organization, which relate to mission, size, structure, and functions;

5. Defines reportable incidents;
 6. Provides metrics for measuring the incident response capability within the organization;
 7. Defines the resources and management support needed to effectively maintain and mature an incident response capability;
 8. Addresses the sharing of incident information;
 9. Is reviewed and approved by [Assignment: organization-defined personnel or roles] [Assignment: organization-defined frequency]; and
 10. Explicitly designates responsibility for incident response to [Assignment: organization-defined entities, personnel, or roles].
- b. Distribute copies of the incident response plan to [Assignment: organization-defined incident response personnel (identified by name and/or by role) and organizational elements];
 - c. Update the incident response plan to address system and organizational changes or problems encountered during plan implementation, execution, or testing;
 - d. Communicate incident response plan changes to [Assignment: organization-defined incident response personnel (identified by name and/or by role) and organizational elements]; and
 - e. Protect the incident response plan from unauthorized disclosure and modification."

IR-9

(Only matters if you have information classifications in place)

What would happen if sensitive information were to 'spill'? (ask legal?)

MA (Target facilities, IT)

MA-1

What policies and procedures around maintenance activities?

MA-2

How is maintenance on systems handled and are vendor/manufacturer guidelines followed?

How is maintenance documented (to include record keeping)?

How is maintenance monitored when its done by non-staff (3rd parties local/remote)?

During remote maintenance how is the session initiated, monitored and when is it terminated (implicitly/explicitly)?

When systems are sent out for maintenance what is the process to ensure data doesn't go with it?

MA-3

What maintenance tools are approved or are any tools prohibited? (more info) GET BETTER UNDERSTANDING OF THIS QUESTION.

MA-4

(ADDRESSED IN MA-2)

MA-5

When 3rd party staff is doing local maintenance how are they authorized, escorted, and by whom?

MA-6

Do all mission critical systems have maintenance support contracts and/or spare parts on-premise?

MP (Target IT)

MP-1

What policies and procedures around Media Protection?

MP-2

Is there any restricted data or media? How is this technically enforced? (for legal?)

Tony Jones, Bob Smith.

Privact Act Data

HR data

Medical records

USB drives are not automounted to computers they need to be mounted by admins

AD controlled data sources.

DLP service

MP-3

What media marking protocols are there and are there any attributes for when to apply or not apply?
(internal docs not needing it, externally distributed marked, financials always, etc.)

MP-4

How are hdd, thumb drives, etc (digital media with company data) handled, sanitized, destroyed?

MP-5

When media with company information travels how is it controlled and ensure secure? (physical backups, ext hdd, print outs)

MP-6

What are the data sanitization processes and are they followed?

MP-7

What restrictions around portable media (usb drives) are there and are they being enforced?

MP-8

Are there multiple levels of information classification?

If yes, whats the process for downgrading information from one classification to the next and is the process being executed consistently?

PE (Target facilities and IT)

PE-1

What policies and procedures around physical and environmental components?

PE-2

How is physical access to the datacenter controlled?

Who is authorized in the datacenter and what is the authorization process?

Are there any logs of people accessing?

Who has actual keys to open an access to the datacenter?

How are keys managed when staff with access leaves?

"a. Develop, approve, and maintain a list of individuals with authorized access to the facility where the system resides;

b. Issue authorization credentials for facility access;

c. Review the access list detailing authorized facility access by individuals [Assignment: organization-defined frequency]; andCyb

d. Remove individuals from the facility access list when access is no longer required."

PE-3

(covered in PE-2)

PE-4

Control physical access to [Assignment: organization-defined system distribution and transmission lines] within organizational facilities using [Assignment: organization-defined security controls].

PE-5

Are there any systems where the output of the system is restricted? (need more info) fax machines, printers, sensitive systems, HR)

Control physical access to output from [Assignment: organization-defined output devices] to prevent unauthorized individuals from obtaining the output.

PE-6

How is physical access monitored, alerted, detect/respond by staff if alert goes off?

Are physical access logs reviewed?

PE-8

How is visitor access recorded?

Is this recording of visitor access reviewed?

What happens if anomalies are detected?

PE-9

How is power equipment and power cabling for the system protected from damage and destruction?

PE-11

How is uninterruptible power supply to facilitate [Selection (one or more): an orderly shutdown of the system; transition of the system to long-term alternate power] in the event of a primary power source loss provided?

PE-16

How is new hardware and systems brought into or removed from the environment? (BETTER ASK THIS)

PE-19

How is the system protected from information leakage due to electromagnetic signals emanations?

PE-20

Is there any asset tracking system to track/monitor any assets?

PL (Target ?)

What policies and procedures around planning?

PL-2

Is there (and review) the system security and privacy plan?

PL-8

What are the security and privacy architectures? (skip)

"a. Develop security and privacy architectures for the system that:

1. Describe the requirements and approach to be taken for protecting the confidentiality, integrity, and availability of organizational information;

2. Describe the requirements and approach to be taken for processing personally identifiable information to minimize privacy risk to individuals;

3. Describe how the architectures are integrated into and support the enterprise architecture; and

4. Describe any assumptions about, and dependencies on, external systems and services;

b. Review and update the architectures [Assignment: organization-defined frequency] to reflect changes in the enterprise architecture; and

c. Reflect planned architecture changes in security and privacy plans, Concept of Operations (CONOPS), criticality analysis, organizational procedures, and procurements and acquisitions."

PM (Target PM, IT, Information Security)

PM-1

What policies and procedures around information security program management?

PM-2

Is there a CISO (or someone with accountability and resources) to implement a infosec program?

PM-3

Is information security included in budgeting efforts, and is the budget supported?

PM-4

"a. Implement a process to ensure that plans of action and milestones for the information security, privacy, and supply chain risk management programs and associated organizational systems:

1. Are developed and maintained;

2. Document the remedial information security, privacy, and supply chain risk management actions to adequately respond to risk to organizational operations and assets, individuals, other organizations, and the Nation; and

3. Are reported in accordance with established reporting requirements.

b. Review plans of action and milestones for consistency with the organizational risk management strategy and organization-wide priorities for risk response actions."

PM-5

Develop and update [Assignment: organization-defined frequency] an inventory of organizational systems.

PM-6

Develop, monitor, and report on the results of information security and privacy measures of performance.

PM-7

Develop and maintain an enterprise architecture with consideration for information security, privacy, and the resulting risk to organizational operations and assets, individuals, other organizations, and the Nation.

PM-8

Address information security and privacy issues in the development, documentation, and updating of a critical infrastructure and key resources protection plan.

PM-9

"a. Develops a comprehensive strategy to manage:

1. Security risk to organizational operations and assets, individuals, other organizations, and the Nation associated with the operation and use of organizational systems; and

2. Privacy risk to individuals resulting from the authorized processing of personally identifiable information;

b. Implement the risk management strategy consistently across the organization; and

c. Review and update the risk management strategy [Assignment: organization-defined frequency] or as required, to address organizational changes."

PM-11

Not in place.

"a. Define organizational mission and business processes with consideration for information security and privacy and the resulting risk to organizational operations, organizational assets, individuals, other organizations, and the Nation; and

b. Determine information protection and personally identifiable information processing needs arising from the defined mission and business processes; and

c. Review and revise the mission and business processes [Assignment: organization-defined frequency]."

PM-12

Not in place.

Implement an insider threat program that includes a cross-discipline insider threat incident handling team.

PM-13

Establish a security and privacy workforce development and improvement program.

PM-14

"a. Implement a process for ensuring that organizational plans for conducting security and privacy testing, training, and monitoring activities associated with organizational systems:

1. Are developed and maintained; and
2. Continue to be executed; and

b. Review testing, training, and monitoring plans for consistency with the organizational risk management strategy and organization-wide priorities for risk response actions."

PM-15

"Establish and institutionalize contact with selected groups and associations within the security and privacy communities:

- a. To facilitate ongoing security and privacy education and training for organizational personnel;
- b. To maintain currency with recommended security and privacy practices, techniques, and technologies; and
- c. To share current security and privacy information, including threats, vulnerabilities, and incidents."

PM-16

Implement a threat awareness program that includes a cross-organization information-sharing capability for threat intelligence.

PM-28

"a. Identify and document:

1. Assumptions affecting risk assessments, risk responses, and risk monitoring;
2. Constraints affecting risk assessments, risk responses, and risk monitoring;
3. Priorities and trade-offs considered by the organization for managing risk; and
4. Organizational risk tolerance;

b. Distribute the results of risk framing activities to [Assignment: organization-defined personnel]; and

c. Review and update risk framing considerations [Assignment: organization-defined frequency]."

PM-29

"a. Appoint a Senior Accountable Official for Risk Management to align organizational information security and privacy management processes with strategic, operational, and budgetary planning processes; and

b. Establish a Risk Executive (function) to view and analyze risk from an organization-wide perspective and ensure management of risk is consistent across the organization."

PM-30

"a. Develop an organization-wide strategy for managing supply chain risks associated with the development, acquisition, maintenance, and disposal of systems, system components, and system services;

1. Implement the supply chain risk management strategy consistently across the organization; and

(a) Review and update the supply chain risk management strategy on [Assignment: organization-defined frequency] or as required, to address organizational changes."

PS (Target HR, IT)

PS-1

What policies and procedures around personnel security are there?

PS-2

What roles have screening criteria to fill those positions?

Same for everyone or is their additional screening for certain roles?

How is the review and application of screening reviewed /updated? (frequency)

PS-3

How is the screening performed and when?

Rescreening occur? For whom/how often?

PS-4

What is the process for voluntary termination? (to include access disabling, IT reclaim)

How are exit interviews performed?

Any assurance of reclaiming company information/property?

PS-5

How often is physical and logical access reviewed and updated as appropriate?

When people switch jobs how is their access reviewed, updated, disabled?

"a. Review and confirm ongoing operational need for current logical and physical access authorizations to systems and facilities when individuals are reassigned or transferred to other positions within the organization;

b. Initiate [Assignment: organization-defined transfer or reassignment actions] within [Assignment: organization-defined time period following the formal transfer action];

c. Modify access authorization as needed to correspond with any changes in operational need due to reassignment or transfer; and

d. Notify [Assignment: organization-defined personnel or roles] within [Assignment: organization-defined time period]."

PS-6

What type of access agreements are staff required to review, sign, approve as part of their access being granted?

Do these agreements need to be reauthorized?

PS-7

What type of personnel security requirements are there for external providers and do they have to agree, review, sign?

Are these requirements documented?

PS-8

If personnel are violating information security/privacy policy what is the sanction process?

Documentation?

PS-9

What type of security and privacy roles and responsibilities are documented into organizational position descriptions?

PT (Target HR, Compliance, Information Security)

PT-1

What policies and procedures around PT? //get more info on PT

RA (Target Risk, Compliance, Information Security, Management

RA-1

What policies and procedures around risk assessment are there?

.

RA-10

What type of threat hunting capabilities are deployed and describe them?

RA-2

How have you identified the security and privacy target states for your system?

(This is very FISMA/Military which is not really applicable to orgs)

"a. Categorize the system and information it processes, stores, and transmits;

b. Document the security categorization results, including supporting rationale, in the security plan for the system; and

c. Verify that the authorizing official or authorizing official designated representative reviews and approves the security categorization decision."

RA-3

How often are risk assessments performed and what is the risk assessment process?

Where is the output of those assessments and how are they communicated to IT, management, business?

RA-5

How is vulnerability scanning performed? (frequency, scope)

What are the outputs of these scans and what is done with them? (both automated tool integration and manual working)

How is risk remediation done from the findings from vuln scans?

RA-7

Respond to findings from security and privacy assessments, monitoring, and audits in accordance with organizational risk tolerance.

RA-9

Identify critical system components and functions by performing a criticality analysis for [Assignment: organization-defined systems, system components, or system services] at [Assignment: organization-defined decision points in the system development life cycle].

SA (Target IT and Apps)

SA-1

What policies and procedures around system acquisition?

SA-2

What is the roadmap for information security and how is the organization funding/budgeting?

Does budgeting have a discrete line item?

SA-3

(LOOK UP REF)

Who has information security and privacy roles and responsibilities?

How are information security and privacy integrated into system development?

"a. Acquire, develop, and manage the system using [Assignment: organization-defined system development life cycle] that incorporates information security and privacy considerations;

b. Define and document information security and privacy roles and responsibilities throughout the system development life cycle;

c. Identify individuals having information security and privacy roles and responsibilities; and

d. Integrate the organizational information security and privacy risk management process into system development life cycle activities."

SA-4

What security requirements are included in contract language?

SA-5

What type of documentation do you have from vendor or developed in house do you have around (and where is it kept, accessible to folks):

(You will verify on administration, configuration, utility of security functionality, end user use)

SA-8

What systems security and privacy engineering principles are best practice? (INTERNAL QUESTION)

In what capacity are they being applied?

Apply the following systems security and privacy engineering principles in the specification, design, development, implementation, and modification of the system and system components: [Assignment: organization-defined systems security and privacy engineering principles].

SA-9

What security requirements do you require of external providers and how are they validated as compliant?

What is the process for giving oversight roles and responsibilities for security of external systems?

SA-10

Look into this to see what the scope is (is it for inhouse dev'd softwares)

What production changes to developed systems are handled through change control?

How are system weaknesses, misconfigurations, need to patch handled and reported?

"Require the developer of the system, system component, or system service to:

a. Perform configuration management during system, component, or service [Selection (one or more): design; development; implementation; operation; disposal];

b. Document, manage, and control the integrity of changes to [Assignment: organization-defined configuration items under configuration management];

c. Implement only organization-approved changes to the system, component, or service;

d. Document approved changes to the system, component, or service and the potential security and privacy impacts of such changes; and

e. Track security flaws and flaw resolution within the system, component, or service and report findings to [Assignment: organization-defined personnel]."

SA-11

How are developed solutions for the system worked and tested prior to being pushed to production (whats the workflow including when tests fail)? (is there a development methodology followed)

Look into this to see what the scope is (is it for inhouse dev'd softwares)

"Require the developer of the system, system component, or system service, at all post-design stages of the system development life cycle, to:

a. Develop and implement a plan for ongoing security and privacy control assessments;

b. Perform [Selection (one or more): unit; integration; system; regression] testing/evaluation [Assignment: organization-defined frequency] at [Assignment: organization-defined depth and coverage];

c. Produce evidence of the execution of the assessment plan and the results of the testing and evaluation;

d. Implement a verifiable flaw remediation process; and

e. Correct flaws identified during testing and evaluation."

SA-15

(Asked above in SA-11)

"a. Require the developer of the system, system component, or system service to follow a documented development process that:

1. Explicitly addresses security and privacy requirements;

2. Identifies the standards and tools used in the development process;
3. Documents the specific tool options and tool configurations used in the development process; and
4. Documents, manages, and ensures the integrity of changes to the process and/or tools used in development; and

b. Review the development process, standards, tools, tool options, and tool configurations [Assignment: organization-defined frequency] to determine if the process, standards, tools, tool options and tool configurations selected and employed can satisfy the following security and privacy requirements: [Assignment: organization-defined security and privacy requirements]."

SA-17

Look into this to see what the scope is (is it for inhouse dev'd softwares)

What product design specification are produced and how is the current overall IT enterprise layout considered.

"Require the developer of the system, system component, or system service to produce a design specification and security and privacy architecture that:

- a. Is consistent with the organization's security and privacy architecture that is an integral part the organization's enterprise architecture;
- b. Accurately and completely describes the required security and privacy functionality, and the allocation of controls among physical and logical components; and
- c. Expresses how individual security and privacy functions, mechanisms, and services work together to provide required security and privacy capabilities and a unified approach to protection."

SA-20

How much of public code reuse is used in development of systems?

Does this include mission critical systems?

Reimplement or custom develop the following critical system components: [Assignment: organization-defined critical system components].

SA-21

What authorization and additional screening (if any) do developers and people with access to modify code?

"Require that the developer of [Assignment: organization-defined system, system component, or system service]:

a. Has appropriate access authorizations as determined by assigned [Assignment: organization-defined official government duties]; and

b. Satisfies the following additional personnel screening criteria: [Assignment: organization-defined additional personnel screening criteria]."

ASK DEVS ABOUT SI-10 (For any custom developed systems that have input fields how is input validation handled?)

SC (Target IT)

SC-1

What policies and procedures around system communication security?

SC-2

Separate user functionality, including user interface services, from system management functionality.

SC-3

Isolate security functions from nonsecurity functions.

SC-4

Prevent unauthorized and unintended information transfer via shared system resources.

SC-5

How does the org protect from denial of service events?

SC-6

Protect the availability of resources by allocating [Assignment: organization-defined resources] by [Selection (one or more): priority; quota; [Assignment: organization-defined controls]].

SC-7

"a. Monitor and control communications at the external managed interfaces to the system and at key internal managed interfaces within the system;

b. Implement subnetworks for publicly accessible system components that are [Selection: physically; logically] separated from internal organizational networks; and

c. Connect to external networks or systems only through managed interfaces consisting of boundary protection devices arranged in accordance with an organizational security and privacy architecture."

SC-8

How is network traffic encrypted (out of the org)?

Could consider internal network traffic depending on org traffic/needs?

SC-10

Are network connections terminated after a period of inactivity?

SC-11

"a. Provide a [Selection: physically; logically] isolated trusted communications path for communications between the user and the trusted components of the system; and

b. Permit users to invoke the trusted communications path for communications between the user and the following security functions of the system, including at a minimum, authentication and re-authentication: [Assignment: organization-defined security functions]."

SC-15

Are all remote collaboration computing devices prohibited from remote activation?

When they are activated is there a visible indicator that its activated?

SC-16

Associate [Assignment: organization-defined security and privacy attributes] with information exchanged between systems and between system components.

SC-18

(define mobile code (is it javascript? Or mobile app)) supplemental guidance Mobile code includes any program, application, or content that can be transmitted across a network (e.g., embedded in an email, document, or website) and executed on a remote system. Decisions regarding the use of mobile code within organizational systems are based on the potential for the code to cause damage to the systems if used maliciously. Mobile code technologies include Java applets, JavaScript, HTML5, WebGL, and VBScript.

How is mobile code from being executed controlled?

What code is prevented or detected and stopped from executing?

What type of attachments are stripped from email being sent into the org?

"a. Define acceptable and unacceptable mobile code and mobile code technologies; and

b. Authorize, monitor, and control the use of mobile code within the system."

SC-20

DNS related

"a. Provide additional data origin authentication and integrity verification artifacts along with the authoritative name resolution data the system returns in response to external name/address resolution queries; and

b. Provide the means to indicate the security status of child zones and (if the child supports secure resolution services) to enable verification of a chain of trust among parent and child domains, when operating as part of a distributed, hierarchical namespace."

SC-21

DNS related

Request and perform data origin authentication and data integrity verification on the name/address resolution responses the system receives from authoritative sources.

SC-22

DNS related

Ensure the systems that collectively provide name/address resolution service for an organization are fault-tolerant and implement internal and external role separation.

SC-23

(Define this)

Where are is network traffic encrypted at session level (TLS?)

Protect the authenticity of communications sessions.

SC-28

Protect the [Selection (one or more): confidentiality; integrity] of the following information at rest:
[Assignment: organization-defined information at rest].

SC-31

"a. Perform a covert channel analysis to identify those aspects of communications within the system that are potential avenues for covert [Selection (one or more): storage; timing] channels; and

b. Estimate the maximum bandwidth of those channels."

SC-37

Employ the following out-of-band channels for the physical delivery or electronic transmission of [Assignment: organization-defined information, system components, or devices] to [Assignment: organization-defined individuals or systems]: [Assignment: organization-defined out-of-band channels].

SC-38

Employ the following operations security controls to protect key organizational information throughout the system development life cycle: [Assignment: organization-defined operations security controls].

SC-44

How is malware dynamically executed safely (i.e. detonation chamber)

SC-47

Establish [Assignment: organization-defined alternate communications paths] for system operations organizational command and control.

SI (Target IT, Information Security)

SI-1

What policies and procedures around system and information integrity are there?

SI-2

How are system flaws (needs for patching) identified and reported on?

How is the patching program (OS, Apps, firmware) handled it? (does it include testing, roll out,e tc)

How is the flaw remediation incorporated in config change management?

SI-3

What is the anti-malware, anti-virus, EDR, MDR, type solution in place?

How is it updated?

Who manages it?

When does it scan systems with frequency?

What does it do when detecting malware?

How are false positives addressed?

SI-4

How does the monitoring and detection of cyber attacks on the environment/system including local/network/remote connections?

How are system events and network traffic captured, monitored, analyzed for malicious activity?

How has legal been included in system monitoring activities?

SI-5

How does staff stay informed on current events related to cybersecurity for their industry, sector, geography, etc.

SI-7

How is software integrity verified? (HARD)

SI-8

What type of spam protection mechanisms do you have implemented?

How are the spam protection maintained and updated?

SI-10

For any custom developed systems that have input fields how is input validation handled?

SI-15

(More info) validation controlled tests of softwares? Argue this would only be mission critical systems.

Validate information output from the following software programs and/or applications to ensure that the information is consistent with the expected content: [Assignment: organization-defined software programs and/or applications].

SI-16

(could argue Windows has DEP/ASLR/CFG/ etc. which addresses this.

Implement the following controls to protect the system memory from unauthorized code execution: [Assignment: organization-defined controls].

SI-18

How is personally identifiable information kept accurate and what is the review process or how people can request updates and how is updates handled?

SR (Target procurement, legal, management, IT)

SR-1

What policies and procedures around supply chain risk management?

SR-2

What is the supply chain risk management plan?

How often is the plan reviewed, updated, communicated?

How is protected from unauthorized edits?

SR-3

How are supply chain risks identified, mitigated, and documented?

SR-5

What acquisition strategies, contract tools, and procurement methods are in place to protect against, identify, and mitigate supply chain risks?

SR-6

How often are supply chain risks assessed and reviewed?

SR-9

What type of tamper protection program for the (mission critical) systems are in place.

SR-10

How often (with evidence) are tamper evident protections verified as not being tampered?

SR-12

How is data and systems disposed?